



Conectar Vistta con tu CRM

Cómo se conecta Vistta con el CRM que el agente ya usa, en las dos direcciones, y qué se envía y qué no. Incluye la parte delicada: por qué el servidor no llama a cualquier dirección que le escriban.

Qué hace

Dos cosas distintas, y la segunda vale mucho más que la primera:

1. **Enlaces automáticos** — tu CRM le pide a Vistta que genere el enlace de un dossier, y se lo guarda en la ficha del contacto. Es comodidad.
2. **Avisos de lectura** — Vistta le cuenta a tu CRM que alguien ha abierto, o **ha vuelto a abrir**, un dossier. Es el termómetro de interés aterrizado donde ya trabajas, y es el momento de llamar.

Se configuran en **Panel** → **Conectar con tu CRM**, y la pantalla está escrita para un comercial: hay un botón de **enviar prueba** porque nadie configura algo que no puede comprobar.

Qué se envía a tu CRM, y qué no

Va	No va
Qué dossier y su referencia	Tiempo por apartado
A quién dijiste que se lo mandabas	Ranking de lo que se miró
Cuándo se abrió y cuántas veces	Si llegó al final
Un enlace de vuelta al panel para ver el detalle	Nada del dispositivo de quien lee

El detalle de la lectura no sale de Vistta, y es una decisión: que tú veas en tu panel «se detuvo en Planos» es una cosa, y mandar el comportamiento de una persona identificada a un sistema de terceros es otra. El aviso trae el enlace; el detalle se consulta aquí.

Al conectar un CRM, ese proveedor pasa a ser **destinatario de datos** de los que tú eres responsable. Está declarado en `legal/rat.md` §B.6, y la pantalla lo dice antes de guardar nada.

Cada aviso va firmado

En la cabecera `X-Vistta-Firma` viaja `t=<marca de tiempo>,v1=<HMAC-SHA256>`, calculado sobre `<marca>.<cuerpo>` con la clave que se te enseñó al crear la conexión. Si tu CRM sabe comprobarla, úsala: es lo que distingue un aviso nuestro de uno que se haya inventado cualquiera que averigüe tu dirección.

La marca de tiempo va **dentro de lo firmado** a propósito: sin ella, quien capture un envío puede reenviarlo mañana y la firma seguiría siendo válida.

Si tu CRM deja de responder

Vista reintenta cada aviso con esperas crecientes. Si se pierden **tres avisos enteros seguidos**, la conexión se apaga sola y te lo dice: en la pantalla de conexiones y en la de Actividad, que es la que abres a diario. Un aviso que no llega en silencio es peor que no tener avisos, porque crees que tu CRM te avisa y no te avisa nadie.

Se vuelve a activar en un clic cuando lo hayas arreglado.

La parte delicada: la dirección la escribes tú

Cuando guardas una dirección, **nuestro servidor va a hacerle peticiones desde dentro de nuestra red**. Sin controles, una dirección apuntando a `localhost`, a la base de datos que no publica puerto, o al servicio de metadatos del proveedor de nube —que entrega credenciales de la máquina a quien las pida— convertiría este formulario en una llave del sistema.

Lo que hay puesto (`src/lib/url-segura.ts`):

- Solo `https://`, solo el puerto 443, y sin usuario ni contraseña en la URL.
- **Se resuelve el nombre y se miran las direcciones**, no el texto: `interno.ejemplo` es un nombre público que puede apuntar a `10.0.0.5`. Se rechaza si **cualquiera** de las direcciones resueltas es privada, no solo la primera.
- La resolución se **fija en el momento de conectar**. Comprobar al guardar y volver a resolver al enviar deja una ventana en la que el mismo nombre puede contestar una dirección pública cuando se comprueba y `127.0.0.1` medio segundo después.
- Y una que encontró una prueba y no el diseño: **cuando el host es una IP literal, Node no llama al resolutor en absoluto**, así que ese caso se corta aparte antes de abrir el socket.
- **No se siguen redirecciones**. Un 302 a `169.254.169.254` se saltaría todo lo anterior de una vez.

Lo que no se ha podido comprobar aquí

- **No se ha hecho un envío completo contra un servidor real**. No se puede desde las pruebas: cualquier servidor que se levante en la máquina de pruebas está en una dirección privada, y el guardia —con razón— lo rechaza. Lo que sí está probado es que la petición **no sale** hacia una dirección interna, que es el fallo que importa. Un envío completo hay que verlo contra un webhook de Make.
- **No se ha probado un ataque de reasignación de DNS de verdad**, con un servidor que conteste distinto en dos consultas seguidas. La defensa está escrita (la resolución se fija), pero comprobarla exige montar un resolutor.
- **Nadie ha confirmado que un agente inmobiliario configure esto**. Es una hipótesis sin validar: un agente que no usa las automatizaciones de su CRM no va a configurar una conexión. Antes de invertir más aquí, conviene preguntar a dos o tres si usan Witei o Inmovilla con automatizaciones.

Dónde está cada cosa

Qué	Dónde
Guardia contra SSRF	<code>src/lib/url-segura.ts</code>
Conexiones de entrada	<code>src/lib/webhooks.ts</code>
Avisos salientes y firma	<code>src/lib/webhooks-salida.ts</code>
La puerta pública	<code>src/routes/webhooks.ts</code>
Gestión desde el panel	<code>src/routes/integracion.ts</code>
Esquema	<code>migrations/0016_webhooks.sql</code>
Pruebas	<code>test/webhooks.spec.ts</code>
Tratamientos declarados	<code>legal/rat.md</code> §B.6 y §B.7